



CLOUD COMPUTING SECURITY

MECR1043

SECTION 52

LECTURER

DR MOHD ZAMRI OSMAN

ASSIGNMENT 1

VIDEO PERSENTATION LINK

<https://eportfolio.utm.my/view/view.php?t=qagY6wVQDzTxXf51jAOo>

NAME	MATRIC NO.
KEERTENNAH DEVI A/P PONNAMBALAM	MEC254026

i. Introduction

a. The Cloud Data Lifecycle

In cloud computing, data transitions through a series of distinct stages, collectively known as the cloud data lifecycle, which spans from its generation to its eventual eradication. Grasping this lifecycle is fundamental for deploying robust security measures that safeguard data confidentiality, integrity, and availability at every stage.

The key phases begin with **Create**, where data is generated or initially ingested into the cloud environment. It then moves to **Store**, where it has persisted within a cloud storage service. During the **Use** phase, data is actively processed, viewed, or modified by applications or users. It may then be **Shared**, meaning it is transmitted or made accessible to external parties or other internal systems. When no longer in active use, data enters the **Archive** phase, moved to long-term, cost-effective storage for compliance or retention. The final phase is **Destroy**, where data is permanently and securely deleted once its retention period expires.

It is crucial to note that these phases are not strictly linear. Data can move back and forth between stages, and a security gap in any single phase can potentially compromise the entire data lifecycle.

b. Chosen CSP and Justification

The chosen Cloud Service Provider is **Amazon Web Services (AWS)**. For this analysis, Amazon Web Services (AWS) was selected due to its market dominance and extensive, well-documented service ecosystem. This model creates an ideal framework for analysis by explicitly distinguishing the security of the cloud, managed by AWS, from the security in the cloud, which is the customer's responsibility. This clarity allows for a precise examination of the data security controls a user must implement throughout the data lifecycle.

Furthermore, AWS provides a comprehensive and natively integrated suite of security tools, alongside extensive documentation and a history of real-world case studies. This ecosystem enables a practical investigation into how security services for identity management, encryption, and data classification can be cohesively applied across all stages of data's life. The platform's widespread enterprise adoption offers credible evidence of both best practices and the tangible consequences of security misconfigurations.

ii. Security Measures in Each Phase

The following analysis details the security controls, access management, and relevant AWS services for each phase of the cloud data lifecycle. **Figure 1** provides a high-level overview of this mapping.

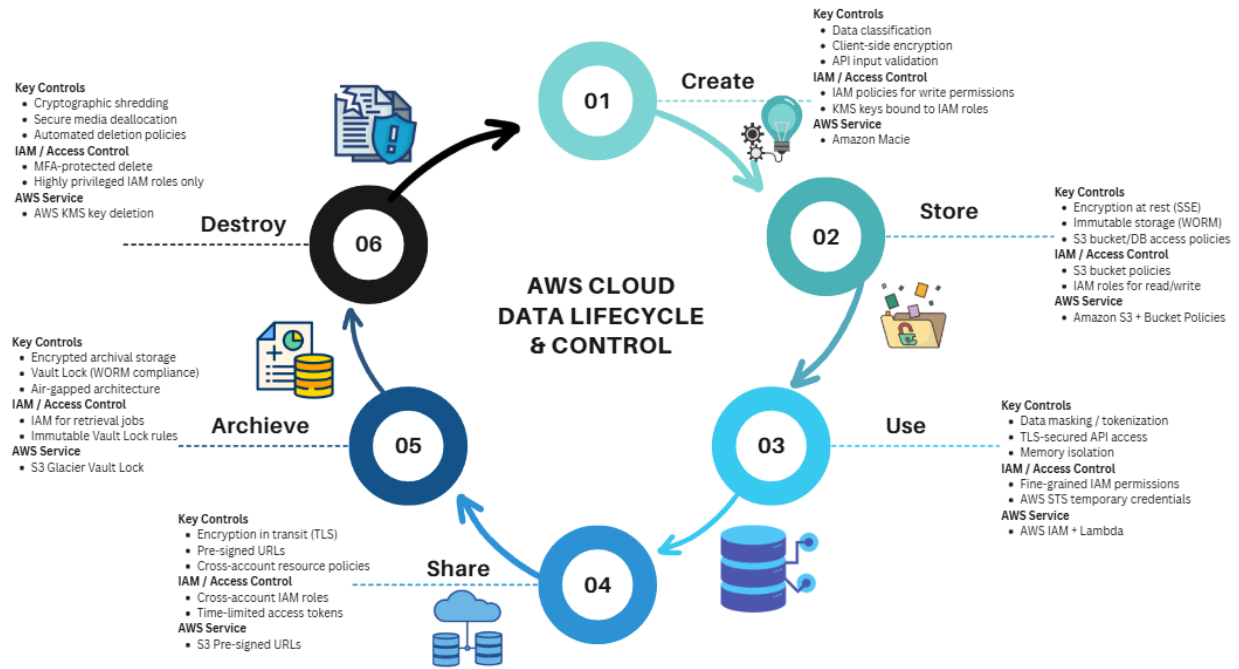


Figure 1: AWS Cloud Data Lifecycle with Mapped Security Controls

The following analysis details the security controls, access management, and relevant AWS services for each phase of the cloud data lifecycle, as summarized in Table 1.

Lifecycle Phase	Key Security Controls	Access Control & Identity Management	Relevant AWS Service/Technology
1. Create	- Data Classification at ingestion - Client-Side Encryption - API Request Validation	- IAM policies control who can write data to which services. - AWS Key Management Service (KMS) keys can be tied to IAM roles for encryption on creation.	Amazon Macie Automatically discovers and classifies sensitive data (like PII) as it is created or uploaded to S3, triggering appropriate security policies.
2. Store	- Server-Side Encryption (at-rest) - Immutable storage	- Resource-based policies (S3 Bucket Policy) define who can access the stored	Amazon S3 with S3 Bucket Policies & Default Encryption S3 provides strong access

	(S3 Object Lock for WORM) - Bucket/DB access policies	data. - IAM roles grant permissions to services to read from storage.	controls and enforces encryption for data at rest, ensuring only authorized principals can access stored objects.
3. Use	- Data Masking and Tokenization - Secure API Endpoints (TLS) - Memory protection and isolation - Secure execution environments (AWS Nitro Enclaves)	- IAM policies for fine-grained access to specific AWS services (which columns in DynamoDB a user can read). - Temporary credentials via AWS STS for short-lived access.	AWS IAM & AWS Lambda IAM policies control which Lambda functions can be invoked and what resources they can access, ensuring the principle of least privilege during data processing.
4. Share	- End-to-End Encryption (in-transit) - Pre-signed URLs with expiry - Resource-based policies for cross-account access	- IAM roles for cross-account access allow secure sharing without exposing long-term credentials. - S3 Pre-signed URLs provide time-limited access to specific objects for external users.	Amazon S3 Pre-signed URLs & AWS Resource Access Manager Pre-signed URLs enable secure, controlled external sharing. AWS RAM helps manage shared resources across accounts.
5. Archive	- Encryption in archival storage - Vault Lock Policies (compliance controls) - Logical air-gapping	- IAM policies are required to initiate retrieval jobs. - Vault Lock policies are immutable and enforce compliance, overriding even root user access.	Amazon S3 Glacier Vault Lock Enforces WORM (Write Once Read Many) storage, allowing the setting of immutable policies to prevent data deletion or modification for a specified retention period.
6. Destroy	- Cryptographic Shredding - Secure Deallocation of physical media	- Highly privileged IAM permissions are required to permanently delete data, often protected with MFA.	AWS Key Management Service (KMS) When a KMS key is scheduled for deletion, after a waiting period, it is cryptographically

	- Automated data lifecycle policies		shredded. Any data encrypted with that key becomes permanently inaccessible, effectively destroying it.
--	-------------------------------------	--	---

Table 1: AWS Security Controls Mapped to the Cloud Data Lifecycle Phases

iii. Interdependency Analysis

a. How Phases Connect to Each Other

The cloud data lifecycle is a highly interconnected system, not a linear sequence. A weakness in any single phase can create a cascading failure, compromising the entire data lifecycle.

- Create → Store

A failure to classify or encrypt data at the point of Creation means that sensitive information is persisted in its raw form during the Store phase. This inherently vulnerable state turns a storage repository like an S3 bucket into a high-value target for a potential breach.

- Store → Use

Weak access controls on a database (Store) mean that when an application fetches data for processing (Use), it could access more information than intended, violating the principle of least privilege.

- Use → Share

If an application processing data (Use) is compromised, it could exfiltrate and (Share) that data maliciously. Conversely, secure sharing mechanisms rely on data being properly processed and prepared for external consumption.

- Share → Use (Feedback loop)

Data that is shared from external sources must be treated as untrusted when it re-enters the Use phase.

- Archive → Destroy

The inability to enforce a strict retention policy in the Archive phase (S3 Glacier Vault Lock) can prevent the secure and timely Destruction of data, leading to compliance violations and unnecessary data exposure.

- Destroy → Create (Policy foundation)

The policies that govern Destruction should directly influence data handling practices at the point of Creation.

b. Potential Vulnerabilities from Incohesive Security

Vulnerability 1: Weak Creation/Storage Controls Enabling Mass Data Exfiltration

The first critical vulnerability, Weak Creation and Storage Controls Enabling Mass Data Exfiltration, originates from fundamental security failures at the initial stages of the data's life, creating a domino effect that neutralizes security measures in later phases. The mechanism begins in the Creation Phase, where data enters the cloud environment without proper classification or sensitivity tagging, meaning systems fail to identify and label sensitive information like PII. This unclassified data then moves to the Storage Phase, where it is placed in cloud storage with overly permissive access policies. The absence of sensitivity tags means automated encryption policies are not triggered, and access controls remain lax. Consequently, attackers with minimal access can freely browse and extract vast amounts of data. Data Loss Prevention (DLP) tools deployed at network egress points remain ineffective because they cannot recognize and block untagged sensitive data, allowing massive exfiltration to occur without triggering alerts.

This pattern was starkly evident in the Verizon Cloud Leak (2017), where misconfigured S3 buckets containing unclassified sensitive data were left publicly exposed, demonstrating how a lack of cohesive controls between the creation and storage phases can lead to unlimited data access.

Vulnerability 2: Inadequate Destruction Undermining Archive Integrity

A second, equally severe vulnerability is Inadequate Destruction Undermining Archive Integrity, which represents a critical mismatch between archival preservation requirements and destruction capabilities. Here, the security controls in one phase directly contradict those in another. The root cause lies in the Archive Phase, where data is placed under legal hold or compliance retention, protected by immutability features like S3 Object Lock that are designed to prevent deletion during a mandated retention period. However, a flaw in the Destruction Phase occurs when overly broad deletion permissions are granted to administrators or automated systems without regard for these archival immutability policies. These excessive permissions can override or bypass the intended protection mechanisms. This allows malicious insiders or attackers with compromised admin accounts to permanently delete legally protected data. Furthermore, even accidental deletion by authorized staff becomes a significant risk when destruction rights are not harmonized with preservation requirements.

The real-world impact of this vulnerability is severe regulatory penalties, such as fines under GDPR or HIPAA, and other legal consequences for failing to preserve data under legal hold, proving that the technical ability to destroy data, if not properly controlled, directly undermines core compliance obligations.

Case Study: The Capital One Data Breach (2019)

This case study reflects directly on Vulnerability 1.

In 2019, Capital One suffered a massive data breach that exposed the personal information of over 100 million customers. The attacker exploited a misconfigured Web Application Firewall (WAF) to steal credentials from an overly powerful IAM role. This role had unnecessary permissions to access data storage in Amazon S3 buckets, allowing the attacker to exfiltrate sensitive information including Social Security numbers and bank account details.

This breach highlights a critical failure in cloud data lifecycle management, specifically the interconnectivity between phases. The primary weakness was located in the "Use" phase, where the web application firewall, a part of data processing, was configured with an IAM role that violated the principle of least privilege by possessing unnecessary and extensive permissions. This misconfiguration directly led to the compromise of the "Store" phase. The excessive permissions granted by the role allowed the attacker to bypass security controls on Amazon S3 buckets, enabling the exfiltration of highly sensitive information, including Social Security numbers and bank account details. Crucially, even though the data was encrypted at rest, the valid but over-privileged credentials granted the attacker full access to it.

The interdependency consequences of this event are stark. It demonstrates conclusively that a misconfiguration in one area, such as application security in the "Use" phase, can completely undermine the security measures in another, such as data storage in the "Store" phase. This proves that cloud security phases cannot be effectively secured in isolation from one another.

The impact of the breach was severe, resulting in \$80 million in regulatory fines and a \$190 million legal settlement for Capital One. Beyond the financial cost, the incident imparted crucial lessons for the entire industry. It reinforced that the principle of least privilege is non-negotiable when configuring IAM roles. Furthermore, it underscored that effective cloud security demands a holistic architectural approach that understands and mitigates how vulnerabilities can propagate across different lifecycle phases. Finally, it established that prevention through rigorous configuration management must be prioritized over relying solely on detection and response mechanisms. This case remains a powerful reminder that in cloud security, every phase is interconnected, and a single weakness can compromise the integrity of the entire system.

iv. Reflection

This analysis has profoundly deepened my understanding of cloud security, revealing it not as a collection of isolated tools, but as a holistic and deeply interdependent system. My perspective has shifted from viewing controls in isolation to appreciating the complex web of relationships that define a secure cloud environment.

A fundamental takeaway is the practical application of the Shared Responsibility Model. I now fully appreciate that while AWS is responsible for the security of the cloud infrastructure, the customer bears the unequivocal responsibility for securing data in the cloud. This duty is exercised directly through the specific configurations and security controls implemented across every phase of the data lifecycle, from creation to destruction.

Furthermore, my understanding of cryptography has evolved significantly. I gained practical insight into how services like AWS Key Management Service (KMS) act as a lifecycle enabler rather than just a storage control. The concept of cryptographic shredding demonstrated that key management is integral to secure data destruction, and that key policies fundamentally govern data accessibility throughout its entire existence, not just when it is at rest.

Another crucial insight is the paramount importance of Identity and Access Management (IAM). This study underscored that IAM functions as the central nervous system of cloud security. The Capital One case study served as a stark reminder that a single over-permissioned IAM role can act as a master key, rendering all other sophisticated encryption and security measures completely ineffective, thereby compromising the entire system.

Most significantly, this study has instilled in me the absolute imperative of a "system thinking" approach. It is clear that one cannot secure a single phase, such as "Store," in isolation. A vulnerability introduced during "Create," "Use," or "Share" will inevitably cascade and compromise stored data. Therefore, designing a resilient security architecture requires meticulously mapping data flows and controls across the entire lifecycle to proactively identify and mitigate these critical interdependencies.

Ultimately, this analysis has reinforced that effective cloud security is not a one-time project but a continuous process. It demands ongoing vigilance in designing, implementing, monitoring, and refining controls at every touchpoint of the data's life to build a truly robust and defensible environment.

v. References

- Amazon Web Services, Inc. (2023). *AWS Key Management Service (KMS) developer guide*. <https://docs.aws.amazon.com/kms/latest/developerguide/overview.html>
- Amazon Web Services, Inc. (2023). *AWS Well-Architected Framework – Security Pillar*. <https://docs.aws.amazon.com/wellarchitected/latest/security-pillar/welcome.html>
- Amazon Web Services, Inc. (2023). *IAM JSON policy elements: Reference*. https://docs.aws.amazon.com/IAM/latest/UserGuide/reference_policies_elements.html
- Cimpanu, C. (2020, June 22). *Capital One agrees to pay \$80 million fine for 2019 data breach*. ZDNet. <https://www.zdnet.com/article/capital-one-agrees-to-pay-80-million-fine-for-2019-data-breach/>
- Garfinkel, S. (2019). The Capital One breach and the cloud. *Communications of the ACM*, 62(12), 22–24.
- Krebs, B. (2017, October 5). *Another day, another unprotected AWS cloud server*. Krebs on Security. <https://krebsonsecurity.com/2017/10/another-day-another-unprotected-aws-cloud-server/>
- Mather, T., Kumaraswamy, S., & Latif, S. (2009). *Cloud security and privacy: An enterprise perspective on risks and compliance*. O'Reilly Media.
- National Institute of Standards and Technology. (2011). *Guidelines on security and privacy in public cloud computing* (Special Publication 800-144). U.S. Department of Commerce.

AI Acknowledgement Statement

In preparing this report, I used an AI language model (DeepSeek) as a tool for brainstorming and structuring initial ideas. All core analysis, critical thinking, integration of references, case study selection, and the creation of the original diagram are my own work. All sources have been cited appropriately in the references section.